

RAPPORT DE TEST D'INTRUSION

TryHackMe — Basic Pentesting

Portfolio public — Laboratoire pédagogique

Auditeur	Dimitri Marquet — dimisan221
Cible	10.128.x.x / 10.129.x.x (THM)
Date	19 juin 2026
Classification	PORTFOLIO PUBLIC
Version	2.0

1. Résumé exécutif

Ce rapport présente les résultats d'un test d'intrusion réalisé sur la machine TryHackMe « Basic Pentesting » dans le cadre d'un exercice pédagogique contrôlé. L'objectif était de simuler une attaque réaliste selon la méthodologie PTES (Penetration Testing Execution Standard) afin d'identifier les vulnérabilités exploitables sur le système cible.

L'évaluation a conduit à la compromission de plusieurs comptes utilisateurs. Un premier accès SSH a été obtenu avec le compte « jan ». La lecture non autorisée de la clé privée de « kay », puis la découverte hors ligne de sa phrase secrète, ont permis de compromettre un second compte et de consulter une donnée sensible. Aucun privilège administrateur (« root ») n'a été obtenu au cours du test.

Criticité	Nombre de vulnérabilités
Critique	0
Élevée	3
Moyenne	1
Faible	0

2. Périmètre et contexte

2.1 Informations générales

Paramètre	Détail
Environnement	TryHackMe (lab isolé)
IP cible	10.128.x.x / 10.129.x.x (dynamique)
Type de test	Boîte noire (Black Box)
Autorisation	Oui — environnement CTF contrôlé
OS détecté	Ubuntu 20.04.6 LTS (Linux 5.15.0)
Durée	19 juin 2026

2.2 Objectifs

- Identifier les services exposés et les vecteurs d'entrée
- Obtenir un accès initial au système
- Compromettre un second compte utilisateur et accéder à ses données sensibles
- Documenter chaque étape selon la méthodologie PTES

3. Méthodologie (PTES)

Le test a été conduit selon les 7 phases définies par le Penetration Testing Execution Standard (PTES) :

Phase PTES	Actions réalisées	Statut
1. Pré-engagement	Définition du périmètre, autorisation THM	✓ Complété
2. Collecte d'informations	Nmap, Gobuster, SMBClient, lecture fichiers	✓ Complété
3. Modélisation des menaces	Identification des utilisateurs jan/kay, services vulnérables	✓ Complété
4. Analyse des vulnérabilités	Mot de passe faible SSH, clé SSH lisible, passphrase crackable	✓ Complété
5. Exploitation	Attaque par dictionnaire SSH, puis compromission successive de jan et kay sur le même hôte	✓ Complété
6. Post-exploitation	Accès au compte kay et consultation de pass.bak, sans privilèges root	✓ Complété
7. Rapport	Ce document	✓ Complété

4. Phase de reconnaissance

4.1 Scan réseau — Nmap

Un scan TCP Connect (`-sT`), sans phase de découverte d'hôte (`-Pn`), a été effectué afin de cartographier les services exposés. L'adresse de la cible étant attribuée dynamiquement à chaque démarrage de l'instance TryHackMe, elle est normalisée ci-dessous sous la forme `` :

```
nmap -sT -Pn -T4 <IP_CIBLE>
```

Port	État	Service	Remarque
22/tcp	Ouvert	SSH	Vecteur d'attaque principal
80/tcp	Ouvert	HTTP (Apache)	Site web en maintenance
139/tcp	Ouvert	NetBIOS-SSN	Transport SMB legacy
445/tcp	Ouvert	Microsoft-DS	SMB moderne
8009/tcp	Ouvert	AJP13	Connecteur Apache Tomcat
8080/tcp	Ouvert	HTTP-Proxy	Interface Tomcat

4.2 Énumération Web — Gobuster

Un fuzzing de répertoires a été lancé sur le serveur HTTP pour découvrir du contenu caché :

```
gobuster dir -u http://<IP_CIBLE>:80 -w /usr/share/wordlists/dirb/common.txt
```

Résultat notable : le répertoire `/development/` a été découvert (HTTP 301), exposant un index Apache sans authentification. Deux fichiers texte y étaient accessibles :

- `dev.txt` : révèle l'utilisation d'Apache Struts 2.5.12 et des informations relatives à SMB ; les messages sont signés « K » et « J »
- `j.txt` : indique que l'utilisateur « J » emploie un mot de passe faible, susceptible d'être découvert par attaque par dictionnaire

4.3 Énumération SMB — smbclient

Le partage SMB Anonymous a été accédé sans authentification :

```
smbclient //<IP_CIBLE>/Anonymous -N
```

Le fichier `staff.txt` récupéré révèle deux noms d'utilisateurs valides : `jan` et `kay`. Ces informations ont directement alimenté la phase d'exploitation.

5. Vulnérabilités identifiées

5.1 [ÉLEVÉE] Mot de passe SSH faible — utilisateur jan

Attribut	Valeur
ID	VULN-001
Sévérité	ÉLEVÉE
CVSS v3 (estimé)	8.2 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N) — estimation
Service affecté	SSH — Port 22/tcp
Utilisateur	jan
Mot de passe découvert	a***** (secret de laboratoire masqué)

Description

L'utilisateur jan dispose d'un mot de passe extrêmement faible, présent dans les wordlists publiques les plus courantes. Un attaquant peut obtenir un accès SSH au compte avec un outil automatisé d'attaque par dictionnaire.

Exploitation

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://<IP_CIBLE> -t 4
```

Résultat : mot de passe découvert (masqué dans cette version publique : `a\*\*\*\*\*`).

Recommandations

- Imposer des mots de passe longs et uniques ; privilégier une longueur minimale de 14 caractères et contrôler leur présence dans les listes de mots de passe compromis
- Privilégier l'authentification SSH par clé et désactiver l'authentification par mot de passe lorsque les contraintes opérationnelles le permettent
- Mettre en place une limitation des tentatives et une surveillance des échecs d'authentification (par exemple Fail2ban)

5.2 [ÉLEVÉE] Clé SSH privée de kay accessible en lecture globale

Attribut	Valeur
ID	VULN-002
Sévérité	ÉLEVÉE
Permissions observées	-rw-r--r-- (644) — lisible par tous les utilisateurs
Fichier	/home/kay/.ssh/id_rsa

Description

La clé privée SSH de l'utilisateur kay présente des permissions incorrectes (644). Tout utilisateur local authentifié peut lire cette clé et tenter de s'en servir pour une connexion SSH.

Exploitation

```
cat /home/kay/.ssh/id_rsa # Depuis la session jan
ssh -i /tmp/kay_id_rsa kay@<IP_CIBLE>
```

Recommandations

- Corriger immédiatement les permissions : `chmod 600 /home/kay/.ssh/id_rsa`
- Auditer régulièrement les permissions des clés privées et des fichiers sensibles
- Appliquer le principe du moindre privilège sur les répertoires home

5.3 [ÉLEVÉE] Passphrase de clé SSH crackable

Attribut	Valeur
ID	VULN-003
Sévérité	ÉLEVÉE
Outil	John the Ripper + rockyou.txt
Passphrase découverte	b***** (secret de laboratoire masqué)
Temps de crack	Moins de 1 minute

Description

Bien que la clé privée soit protégée par une passphrase, celle-ci est trop faible pour résister à une attaque par dictionnaire. Un attaquant ayant récupéré la clé peut l'utiliser rapidement.

Exploitation

```
ssh2john /tmp/kay_id_rsa > /tmp/kay_hash.txt
john /tmp/kay_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Résultat : phrase secrète découverte (masquée dans cette version publique : `b\*\*\*\*\*`).

Recommandations

- Utiliser une phrase secrète longue, unique et résistante aux attaques hors ligne
- Envisager l'utilisation d'un gestionnaire de mots de passe pour générer et stocker les passphrases

5.4 [MOYENNE] Divulgation d'informations via partage SMB anonyme

Attribut	Valeur
ID	VULN-004
Sévérité	MOYENNE
Service	SMB — Ports 139/445
Partage	Anonymous (accessible sans authentification)

Description

Le serveur expose un partage SMB accessible sans authentification contenant le fichier staff.txt, qui révèle les noms des utilisateurs du système. Cette information a directement permis de cibler l'attaque par dictionnaire.

Recommandations

- Désactiver les partages anonymes SMB si non nécessaires
- Ne pas stocker d'informations sur les utilisateurs dans des partages accessibles sans authentification
- Restreindre l'accès SMB aux seuls utilisateurs authentifiés et nécessaires

6. Chaîne d'exploitation

L'exploitation a suivi une chaîne logique en six étapes :

Étape	Action	Résultat
1	Reconnaissance réseau et web	Services SSH, HTTP et SMB identifiés
2	Énumération du partage SMB anonyme	Comptes utilisateurs jan et kay identifiés
3	Attaque par dictionnaire contre SSH	Accès initial obtenu avec le compte jan
4	Contrôle des fichiers accessibles depuis jan	Clé privée SSH de kay récupérée
5	Attaque hors ligne de la phrase secrète	Phrase secrète de la clé découverte
6	Authentification SSH avec la clé de kay	Compte kay compromis et donnée sensible consultée ; aucun accès root

7. Recommandations prioritaires

Priorité	Action	Vulnérabilité ciblée
P1 — Immédiat	Privilégier les clés SSH ; désactiver l'authentification par mot de passe lorsque possible	VULN-001
P1 — Immédiat	Corriger permissions id_rsa : chmod 600	VULN-002
P2 — Court terme	Renouveler la clé SSH de kay avec passphrase forte	VULN-003
P2 — Court terme	Désactiver ou sécuriser le partage SMB anonyme	VULN-004
P3 — Moyen terme	Limiter et superviser les tentatives d'authentification SSH	VULN-001
P3 — Moyen terme	Automatiser l'audit des permissions des fichiers sensibles	VULN-002
P3 — Moyen terme	Sensibiliser à l'usage de mots de passe et phrases secrètes uniques	Toutes

8. Conclusion

Ce test d'intrusion démontre qu'une combinaison de vulnérabilités de sévérité variable peut conduire à la compromission successive de plusieurs comptes utilisateurs et à l'accès non autorisé à des données sensibles. Le scénario documenté s'arrête au compte «kay» : aucun accès administrateur («root») n'a été obtenu. Les failles exploitées reposent sur des erreurs de configuration basiques et le non-respect de politiques de sécurité élémentaires.

Le risque principal réside dans la combinaison d'un mot de passe SSH faible et de permissions excessives sur une clé privée. La mise en œuvre de l'une des mesures prioritaires interromprait la chaîne d'exploitation documentée ; leur application conjointe apporte une défense en profondeur.

Il est fortement recommandé de procéder à un nouveau test d'intrusion après application des correctifs afin de valider leur efficacité.